



Análisis y Planificación del Pentest

Actividad 1

Norma Martínez



CONTEXTO

Aurora Market

- Empresa mexicana con crecimiento rápido en ventas a través de su aplicación web.
- La aplicación web es estratégica porque cuenta con información sensible de los clientes y representa miles de pedidos.

Objetivos generales

- Realizar la primera evaluación de seguridad formal de la aplicación web.
- Apoyo al equipo de Tecnología ante la situación donde aparentemente un usuario visualizó información de otra cuenta.

OBJETIVO DEL PENTEST

-  Ejecutar la prueba de seguridad simulando un ciberataque real en un entorno controlado e identificar posibles vulnerabilidades en la aplicación web y aclarar el origen del reporte del usuario.
-  De los hallazgos, medir su impacto y brindar recomendaciones pertinentes.
-  Entregar información documentada, clara y útil para que la organización implemente recomendaciones emitidas.

ALCANCE

Evaluación

- Se evaluará únicamente la aplicación web autorizada por Aurora Market; considerando funcionalidades de autenticación, carrito de compras, consultas, perfiles y panel de administración.

Exclusiones

- Redes sociales de la empresa, equipos personales de colaboradores, cuentas de correo, proveedores externos, sistemas que no formen parte del alcance.
- Acciones que interrumpan la plataforma o afecten información real de los clientes de manera intencional.

AUTORIZACIÓN Y CONDICIONES

Permisos Requeridos

- Autorización escrita para dar inicio al ejercicio de pentest.
- Credenciales para simular accesos desde distintos roles (colaborador, administrativo, cliente) sin alterar datos reales.
- Agregar a listas blancas IPs del equipo auditor, a fin de evitar bloqueos automáticos durante las pruebas.

Condiciones acordadas

- Pruebas exclusivamente a la aplicación web autorizada y ejecución en horarios de menor actividad.

TIPO DE PENTEST

Caja Gris

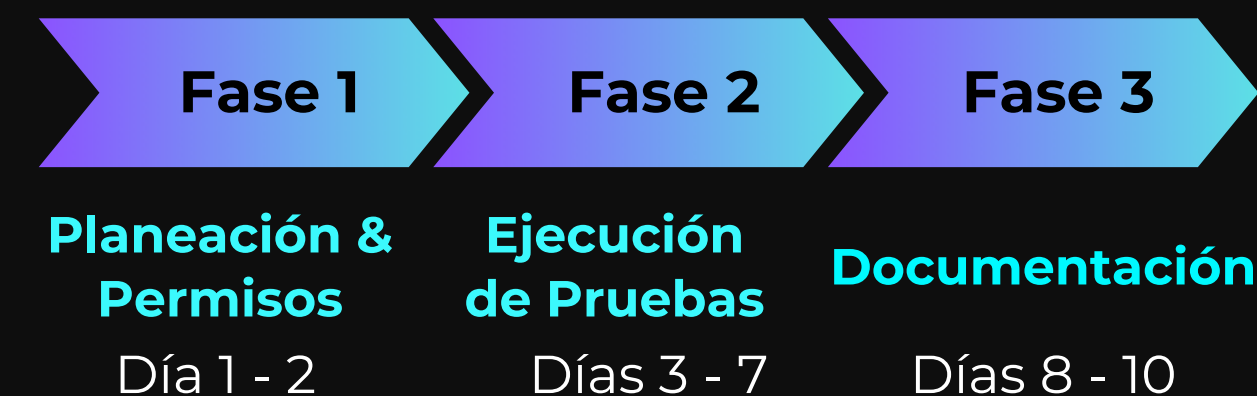
- El equipo auditor cuenta con información parcial, limitada, sobre la aplicación web antes de comenzar el ejercicio.

Sustento

- El escenario de Caja Gris se debe a que el equipo auditor, sabe que existe una aplicación web, una base de datos, mecanismos de autenticación y diferentes roles de usuario; sin embargo, desconoce mayores detalles, como los de la infraestructura existente.

PLANIFICACIÓN

- **Objetivos y Alcance.** Evaluar la web autorizada sin tocar redes, correos ni proveedores.
- **Permisos y Condiciones.** Autorización formal y pruebas sin afectaciones.
- **Metodología e Información.** Marco OWASP: WSTG y ASVS.
- **Recursos.** Equipo auditor, herramientas de análisis y accesos del cliente.
- **Programación.** Cronograma de ejecución adaptado a ventanas de menor actividad.



FASES DEL PENTEST

Reconocimiento. Descubrir la estructura de la aplicación web y elementos expuestos sin afectar el entorno.

Análisis de vulnerabilidades. Buscar vulnerabilidades de configuración, autenticación y permisos en distintos roles.

Explotación. Acciones que puedan comprometer a la aplicación web, usuarios o información (en entorno controlado).

Post explotación. Movimiento lateral y evaluación de riesgos sobre datos de clientes (sin afectar el servicio).

Informe. Documentación de hallazgos, evidencias y recomendaciones específicas.

INVESTIGACIÓN

Metodología elegida. OWASP: WSTG y ASVS.

Por qué sería útil para este proyecto.

- **WSTG.** *Web Security Testing Guide* (Guía de Pruebas de Seguridad Web). Marco de trabajo de OWASP, recopila las mejores prácticas técnicas para evaluar la seguridad de aplicaciones y servicios web.
- **ASVS.** *Application Security Verification Standard* (Estándar de Verificación de Seguridad en Aplicaciones). Guía de OWASP que define requisitos y controles técnicos de seguridad para diseñar, desarrollar y probar aplicaciones seguras.